PharmaSoft | Informe de seguridad S10

Lenguaje de Programación II · Unidad 2 · Sesión 4 · 18 de octubre de 2026

1. Objetivo y alcance

Se corrigió la conexión Oracle del proyecto AP9 y se implementó la actividad autónoma S10: autenticación JWT, permisos por rol, cambio de contraseña, asignación de roles y activación/desactivación de usuarios. También se integraron las pantallas Angular para usar estas funciones.

2. Entorno verificado

Componente	Configuración observada
Oracle	Oracle Free 23.26.1, contenedor oracle-local, host 1522 hacia contenedor 1521, servicio FREEPDB1, esquema SYSVENTAS.
Backend	Spring Boot 4, Java 24, API en http://localhost:8081/api/v1.
Frontend	Angular 22, http://localhost:4200; login, catálogo y pantalla de usuarios comprobados en Chrome.
Datos	69 categorías visibles desde la SPA; 5 cuentas de prueba de seguridad en desarrollo.

3. Método y resultados

Se ejecutaron 28 casos principales sobre HTTP real (16 base, 4 propios y 8 B1-B3), más 7 verificaciones complementarias. Se comparó el estado obtenido con el esperado y se guardó un JSON por ID sin tokens ni contraseñas. Las cuentas modificadas durante las pruebas fueron restauradas.

Grupo	Casos	Resultado
Autenticación A	4	4 correctos
Token T	5	5 correctos
Permisos P	4	4 correctos
Usuarios U	2	2 correctos
Conexión C	1	1 correcto
Propios X	4	4 correctos
Requerimientos B	8	8 correctos
Total	28	28/28 correctos

Evidencia principal: docs/matriz-seguridad-s10.md y docs/evidencias-s10/<ID>.json. El archivo Postman se entrega sin credenciales ni JWT reales.

Hallazgos y correcciones

4. Fichas de hallazgos

ID / severidad	Evidencia y causa	Corrección / estado
H-01 / Alta	El perfil dev apuntaba a localhost:1521, mientras Oracle del proyecto expone el contenedor por 1522. Ese puerto corresponde a otra instancia local.	URL dev cambiada a jdbc:oracle:thin:@localhost:1522/FREEPDB1. Hikari conectó a SYSVENTAS y C-01 devolvió categorías. Resuelto.
H-02 / Media	Un JWT emitido antes de cambiar la contraseña podía seguir vigente hasta expirar si solo se verificaba firma y fecha.	El token lleva una huella del hash BCrypt; el filtro la compara con la credencial actual. B-01a obtuvo 401 con el token anterior. Resuelto.
H-03 / Baja	El origen 127.0.0.1:4200 no estaba en la lista CORS inicial; el servidor Angular también puede iniciarse con ese host.	Se añadieron localhost y 127.0.0.1 para los puertos de desarrollo 4200/4201. Los orígenes de producción son configurables. Resuelto.

No quedan casos fallidos en la matriz ejecutada. El estado PASS demuestra los escenarios listados, no una auditoría exhaustiva de producción.

5. Diseño de los requerimientos nuevos

Requisito	Implementación	Evidencia
B1: PUT /auth/password	Usuario autenticado, validación 8-72 con letra y número, BCrypt, 204; 409 si la contraseña actual falla o se repite la nueva. El token previo queda revocado.	B-01, B-02, B-03, B-01a, B-03a
B2: PUT /usuarios/{id}/roles	ADMIN, conjunto de roles válido, 404 para ID inexistente, 409 si ADMIN se quita su propio rol; permisos recargados de BD por petición.	B-04, B-05, B-08, B-04a, B-05a
B3: PATCH /usuarios/{id}/estado	ADMIN, 404 si no existe, 409 si intenta desactivarse a sí mismo; token previo de usuario inactivo obtiene 401.	B-06, B-07, B-06a, B-07a

6. Revisión de frontend

La SPA usa inicio de sesión, interceptor Bearer, cierre de sesión ante 401, guardas de rutas y menú según permisos. Hay vistas para cambiar la contraseña y administrar roles/estado. El backend mantiene la autorización efectiva; ocultar enlaces en Angular solo mejora la navegación.

Análisis y reproducción

7. Preguntas de análisis de la guía

¿El login revela si falló el usuario o la contraseña? No. Credenciales erradas y cuenta deshabilitada responden 401 con mensaje uniforme: "Usuario o contraseña incorrectos" (A-03 y A-04).

¿Qué ocurre con un token anterior tras cambiar contraseña? El filtro verifica la huella de la contraseña almacenada en cada petición. Al cambiar el hash BCrypt, el token anterior devuelve 401 (B-01a); es necesario volver a iniciar sesión.

¿Qué pasa si se filtra la clave JWT? Quien la posea podría firmar tokens válidos. Debe rotarse JWT_SECRET desde un gestor de secretos o variable de entorno, reiniciar la API para invalidar firmas previas, revisar accesos y emitir nuevas sesiones. La clave y los tokens no se guardan en Git ni en Postman.

¿Basta proteger una URL o conviene proteger métodos? Las reglas por URL controlan el tráfico HTTP. La comprobación en métodos protege la operación si cambia el mapeo o se invoca desde otro controlador. El proyecto usa reglas por ruta y @PreAuthorize para reportes; las operaciones de usuarios están restringidas por URL. Conviene extender anotaciones de método a todo servicio crítico en una fase de endurecimiento.

8. Cómo reproducir

1. Iniciar oracle-local y comprobar el mapeo 1522:1521. Configurar DB_USERNAME, DB_PASSWORD y JWT_SECRET (Base64 de al menos 32 bytes).

2. En desarrollo, habilitar APP_SEED_DEMO_SECURITY=true y fijar PHARMA_DEMO_PASSWORD con una clave de prueba propia. Desde backend, ejecutar .\mvnw.cmd spring-boot:run.

3. En la raíz, ejecutar npm ci y npm start. Abrir http://localhost:4200, iniciar sesión y revisar Catálogo, Usuarios y Mi cuenta.

4. Ejecutar scripts/verify_s10.py con PHARMA_DEMO_PASSWORD definido. Revisar la matriz y sus JSON. La colección Postman requiere completar sus variables locales y ejecutar sobre datos de demostración.

9. Límites y próximos pasos

La prueba se hizo en el Oracle local del curso. El perfil dev usa Hibernate ddl-auto:update; para despliegue se recomienda una migración versionada. El cierre de sesión limpia el token del navegador, pero un JWT copiado sigue válido hasta caducar si no cambió la contraseña ni se desactivó la cuenta. No se probó una carga multiusuario ni un despliegue remoto.

La guía solicita trabajo en rama, colección, matriz e informe. Esta copia está en feature/seguridad-pruebas-tinoco. La entrega en B-Learning y el PR requieren acciones separadas; este informe registra solo el trabajo local verificado.